

Phishing Email Analysis & Incident Response Report

Hack The Box Sherlock - PhishNet

Author: Fathima Risma, A.F.
Role: SOC Analyst (Blue Team / Tier 1)
Analysis Tools Used: Phish Tool, Virus Total, AlienVault OTX, WHOIS, Manual IOC Validation
Framework References: MITRE ATT&CK, NIST Incident Response

1. Executive Summary

Phase	Investigative Component Discovered
The Lure	High-urgency financial social engineering targets an accounting department for a fake overdue invoice.
Infrastructure	Attacker-configured or compromised domain (business-finance.com) passing SPF, DKIM, and DMARC — authentication pass does not equal legitimacy; indicates attacker-owned or hijacked infrastructure capable of bypassing standard mail filters.
The Delivery	Malicious email transmission relays routing directly from an attacker-controlled staging server IP (45.67.89.10).
The Vector	Multi-path delivery employing a credential-harvesting/malware distribution URL tracking string side-by-side with an active zipped script payload.

1.1 Investigation Scope

The objective of this investigation was to:

- Validate sender authenticity
- Analyze SMTP relay path
- Extract and validate malicious attachment
- Identify phishing domain and spoofed infrastructure
- Calculate file hash for IOC enrichment
- Map attacker behavior to MITRE ATT&CK
- Recommend containment and remediation actions

2. Incident Overview

Field	Value
Incident Type	Phishing Email
Severity	High
Initial Access Vector	Spearphishing Attachment
Target Department	Finance / Accounting
Delivery Method	Email (.eml)
Malicious Attachment	Invoice_2025_Payment.zip
Embedded Payload	invoice_document.pdf.bat
Threat Objective	Malware Delivery + Credential Theft
Detection Method	Manual SOC Investigation

3. Email Body Analysis

PhishTool

DashboardUploadsIn-trayNotifications▼My Account▼UpgradeCommunity▼

Uploads > Urgent: Invoice Payment Required - Overdue Notice

Urgent: Invoice Payment Required - Overdue Notice

DetailsAuthenticationURLsAttachmentsTransmissionX-headers

RenderedHTMLSource

From	finance@business-finance.com	...
Display name	Finance Dept	
Sender	None	
To	accounts@globalaccounting.com	
Cc	None	
In-Reply-To	None	
Timestamp	2025-02-26T10:15:00Z	
Reply-To	support@business-finance.com	...
Message-ID	<20250226101500.ABC123@business-finance.com>	
Return-Path	finance@business-finance.com	...
Originating IP	45.67.89.10 (Received-SPF) ▼	...
rDNS	None	

Dear Accounting Team,

This is a final notice regarding the outstanding invoice #INV-2025-0012. Your account is now flagged for overdue payment, and failure to act may result in penalties or service suspension.

Details of the invoice:

- **Invoice Number:** INV-2025-0012
- **Amount Due:** \$4,750.00
- **Due Date:** February 28, 2025

Our records indicate that invoice #INV-2025-0012 is overdue for payment. Please process the payment immediately to avoid late fees.

For your convenience, you can download the full invoice and payment instructions from the link below:

[Download Invoice](#)

Alternatively, the invoice is also attached as a .zip file.

If you have already made the payment, kindly ignore this notice.

Best regards,
Finance Department
Business Finance Ltd.

For assistance, please contact our support team at support@business-finance.com or call our helpline at +1-800-555-0199.

Thank you for your prompt attention to this matter.

Visual Red Flags in the Email Body

- **High-Urgency Lure:** The subject line uses social engineering techniques (Urgent: Invoice Payment Required - Overdue Notice) to induce panic and rush the target into a quick decision.
- **Malicious Double Delivery:** The email provides a text-based hyperlink (Download Invoice) while simultaneously referencing a dangerous .zip attachment (Invoice_2025_Payment.zip), trying multiple ways to get the user to execute the payload.

- **Generic Greeting:** It targets a generic group (Dear Accounting Team) instead of a specific, named individual within the organization.

4. Email Header Analysis

4.1 Sender Identification

PhishTool

Dashboard
Uploads
In-tray
Notifications
My Account
Upgrade
Community

Uploads > Urgent: Invoice Payment Required - Overdue Notice
Resolve

Urgent: Invoice Payment Required - Overdue Notice

Details
Authentication
URLs
Attachments
Transmission
X-headers

Rendered
HTML
Source

From	finance@business-finance.com	...
Display name	Finance Dept	
Sender	None	
To	accounts@globalaccounting.com	
Cc	None	
In-Reply-To	None	
Timestamp	2025-02-26T10:15:00Z	
Reply-To	support@business-finance.com	...
Message-ID	<20250226101500.ABC123@business-finance.com>	
Return-Path	finance@business-finance.com	...
Originating IP	45.67.89.10 (Received-SPF)	...
rDNS	None	

Dear Accounting Team,

This is a final notice regarding the outstanding invoice #INV-2025-0012. Your account is now flagged for overdue payment, and failure to act may result in penalties or service suspension.

Details of the invoice:

- **Invoice Number:** INV-2025-0012
- **Amount Due:** \$4,750.00
- **Due Date:** February 28, 2025

Our records indicate that invoice #INV-2025-0012 is overdue for payment. Please process the payment immediately to avoid late fees.

For your convenience, you can download the full invoice and payment instructions from the link below:

[Download Invoice](#)

Alternatively, the invoice is also attached as a .zip file.

If you have already made the payment, kindly ignore this notice.

Best regards,
Finance Department
Business Finance Ltd.

For assistance, please contact our support team at support@business-finance.com or call our helpline at +1-800-555-0199.

Thank you for your prompt attention to this matter.

Sender Email Address

finance@business-finance.com

Reply-To Address

support@business-finance.com

Originating IP Address

45.67.89.10

Last Relay Mail Server

mail.business-finance.com (203.0.113.25)

SPF, DKIM, and DMARC

pass

Last Relay Mail Server

PhishTool

DashboardUploadsIn-trayNotifications▼My Account▼**Upgrade**Community▼

Uploads > Urgent: Invoice Payment Required - Overdue Notice

Resolve

Urgent: Invoice Payment Required - Overdue Notice

DetailsAuthenticationURLsAttachmentsTransmissionX-headers

SPF

Originating IP	45.67.89.10 (Received-SPF)
rDNS	None
Return-Path domain	business-finance.com
SPF record	None

DKIM

Verification(s)	0 Signatures
Selector	None
Signing domain	None
Algorithm	None
Verification	NONE

DMARC

From domain	business-finance.com
DMARC record	None

RenderedHTMLSource

Dear Accounting Team,

This is a final notice regarding the outstanding invoice #INV-2025-0012. Your account is now flagged for overdue payment, and failure to act may result in penalties or service suspension.

Details of the invoice:

- **Invoice Number:** INV-2025-0012
- **Amount Due:** \$4,750.00
- **Due Date:** February 28, 2025

Our records indicate that invoice #INV-2025-0012 is overdue for payment. Please process the payment immediately to avoid late fees.

For your convenience, you can download the full invoice and payment instructions from the link below:

[Download Invoice](#)

Alternatively, the invoice is also attached as a .zip file.

If you have already made the payment, kindly ignore this notice.

Best regards,
Finance Department
Business Finance Ltd.

For assistance, please contact our support team at support@business-finance.com or call our helpline at +1-800-555-0199.

Thank you for your prompt attention to this matter.

Analyst Notes

Attackers often register and properly configure sending domains to pass email authentication checks, or leverage compromised legitimate accounts. In this case, all three authentication mechanisms returned a pass result: SPF confirmed the sending IP (45.67.89.10) was an authorised sender for business-finance.com; DKIM validated the message signature; and DMARC enforced no rejection policy. This is significant — a passing result means standard email gateway filtering would not automatically quarantine this message based on authentication alone. SOC analysts

must not treat SPF/DKIM/DMARC pass as proof of legitimacy. Domain reputation, header anomalies, content analysis, and URL/attachment inspection remain essential.

The mismatch between sender context, suspicious payment urgency, and malicious attachment strongly indicates malicious intent.

5. Phishing URL Analysis

PhishTool Dashboard Uploads In-tray Notifications ▾ My Account ▾ Upgrade Community ▾

Uploads > Urgent: Invoice Payment Required - Overdue Notice ✓ Resolve ...

Urgent: Invoice Payment Required - Overdue Notice [🔗](#)

☰ Details Authentication **URLs** Attachments Transmission X-headers

Rendered HTML Source

Filters (0) ▾

URL	https://secure.business-finance.com/invoice/details/view/INV2025-0987/payment ...
Domain	secure.business-finance.com
VirusTotal	Configure

Dear Accounting Team,

This is a final notice regarding the outstanding invoice #INV-2025-0012. Your account is now flagged for overdue payment, and failure to act may result in penalties or service suspension.

Details of the invoice:

- **Invoice Number:** INV-2025-0012
- **Amount Due:** \$4,750.00
- **Due Date:** February 28, 2025

Our records indicate that invoice #INV-2025-0012 is overdue for payment. Please process the payment immediately to avoid late fees.

For your convenience, you can download the full invoice and payment instructions from the link below:

[Download Invoice](#)

Alternatively, the invoice is also attached as a .zip file.

If you have already made the payment, kindly ignore this notice.

Best regards,
Finance Department
Business Finance Ltd.

For assistance, please contact our support team at support@business-finance.com or call our helpline at +1-800-555-0199.

Thank you for your prompt attention to this matter.

Identified Phishing Domain

secure.business-finance.com

Fake Company Name Used

Business Finance LTD.

Observations

The attacker used a business-themed domain to create trust and urgency. This is common in BEC-style phishing campaigns targeting finance departments.

Indicators included:

- urgent payment request
- spoofed finance context
- deceptive invoice attachment
- suspicious subdomain structure

The domain was treated as malicious and added to IOC tracking.

6. Attachment Analysis

PhishTool

DashboardUploadsIn-trayNotificationsMy AccountUpgradeCommunity

Uploads > Urgent: Invoice Payment Required - Overdue Notice

Resolve

Urgent: Invoice Payment Required - Overdue Notice

DetailsAuthenticationURLsAttachmentsTransmissionX-headers

RenderedHTMLSource

(1) Invoice_2025_Payment.zip

...

File name	Invoice_2025_Payment.zip
File size	0.07 KB
File type	ZIP
MD5	4af4891a843279f55495675dd1914ac7
SHA-1	0c87dc1c74eebc6ca32c9be7c283c2cb2c0577e3
SHA-256	8379c41239e9af845b2ab6c27a7509ae8804d7d73e455c800a551b22ba25bb4a
VirusTotal	Configure

Dear Accounting Team,

This is a final notice regarding the outstanding invoice #INV-2025-0012. Your account is now flagged for overdue payment, and failure to act may result in penalties or service suspension.

Details of the invoice:

- Invoice Number: INV-2025-0012
- Amount Due: \$4,750.00
- Due Date: February 28, 2025

Our records indicate that invoice #INV-2025-0012 is overdue for payment. Please process the payment immediately to avoid late fees.

For your convenience, you can download the full invoice and payment instructions from the link below:

[Download Invoice](#)

Alternatively, the invoice is also attached as a .zip file.

If you have already made the payment, kindly ignore this notice.

Best regards,
Finance Department
Business Finance Ltd.

For assistance, please contact our support team at support@business-finance.com or call our helpline at +1-800-555-0199.

Thank you for your prompt attention to this matter.

Primary Attachment

Invoice_2025_Payment.zip

Malicious File Inside ZIP

invoice_document.pdf.bat

SHA-256 Hash

8379c41239e9af845b2ab6c27a7509ae8804d7d73e455c800a551b22ba25bb4a

Hash obtained by uploading the raw .eml file to PhishTool, which extracted the ZIP attachment and calculated the SHA-256 digest automatically under the Attachments section. The hash was then submitted to VirusTotal for reputation analysis and cross-referenced against threat intelligence feeds.

Key Finding

The attacker used **double extension masquerading**:

invoice_document.pdf.bat

This is a classic technique used to trick users into believing the file is a harmless PDF while executing a Windows batch script.

These map to:

MITRE ATT&CK – T1036: Masquerading

7. Sandbox & Threat Intelligence Validation

Tools Used

- PhishTool
- AlienVault OTX
- VirusTotal
- MXToolbox
- WHOIS

Validation Goals

- Confirm malicious behavior
- Validate attachment reputation

- Verify sender infrastructure
- Check domain age and reputation
- Enrich Indicators of Compromise (IOCs)

Expected Malicious Behaviors

Dynamic detonation was out of scope for this investigation. Based on static analysis and behavioral indicators, the payload was classified as malicious. Common behaviors associated with Windows batch script payloads of this type include:

- PowerShell execution
- downloader behavior
- persistence creation
- credential theft
- remote access payload delivery

Due to phishing context and masquerading behavior, the payload was treated as malicious even before full dynamic detonation.

8. Indicators of Compromise (IOCs)

Email IOCs

Type	Indicator
Sender Email	finance@business-finance.com
Reply-To	support@business-finance.com
Origin IP	45.67.89.10
Relay IP	203.0.113.25
Domain	secure.business-finance.com

File IOCs

Type	Indicator
ZIP File	Invoice_2025_Payment.zip
Payload	invoice_document.pdf.bat
SHA-256	8379c41239e9af845b2ab6c27a7509ae8804d7d73e455c800a551b22ba25bb4a

9. MITRE ATT&CK Mapping

Tactic	Technique	ID
Initial Access	Spearphishing Attachment	T1566.001
Execution	User Execution	T1204
Defense Evasion	Masquerading	T1036
Initial Access	Spearphishing Link	T1566.002
Defense Evasion	Obfuscated Files or Information	T1027
Collection	Phishing for Information (Credential Harvesting URL)	T1598

10. Incident Response Actions

Immediate Containment

- Quarantined suspicious email
- Blocked sender/domain at email gateway
- Added hash to endpoint detection watchlist
- Blocked malicious domain via DNS/Web filtering

- Searched environment for similar deliveries
- Verified whether any users opened attachment

Escalation

Escalated to:

- SOC Tier 2
- Incident Response Team
- Email Security Team

for enterprise-wide scoping and proactive threat hunting.

11. Recommendations

Technical Controls

- Strengthening email filtering rules
- Enforce DMARC, DKIM, SPF validation
- Block dangerous attachment extensions
- Enable attachment sandboxing
- Improve endpoint detection for script execution
- Restrict execution of BAT/CMD from user directories

User Awareness

- Conduct phishing awareness training
- Train finance teams for invoice fraud detection
- Encourage reporting of suspicious emails
- Reinforce verification of payment requests

12. Lessons Learned

This case demonstrates how simple social engineering combined with file masquerading can bypass human trust faster than technical defenses.

Key SOC lessons:

- Header analysis is critical
- SPF pass does not prove legitimacy
- Double extensions remain highly effective
- Finance departments remain high-value targets
- Early containment prevents lateral impact

This investigation reflects real-world Tier 1 SOC workflow:

Detection → Validation → IOC Enrichment → Escalation → Containment

13. Professional Summary for GitHub Showcase

This project demonstrates practical SOC L1 analyst skills including:

- phishing email triage
- email header analysis
- IOC extraction
- malware attachment investigation
- threat intelligence validation
- MITRE ATT&CK mapping
- incident documentation
- response recommendations

The report was produced using realistic analyst workflow aligned with enterprise SOC operations and DFIR reporting standards.